

VULNERABILITY ASSESSMENT REPORT

A Passive Security Assessment of scanme.nmap.org

Prepared By	Brian Amani Mlenge
Track	Cyber Security (CS)
Task	Task 01 — Vulnerability Assessment Report for a Live Website
Github Repository	FUTURE_CS_01
Assessment Target	scanme.nmap.org (authorized test host)
Assessment Type	Passive Reconnaissance and Configuration Review
Date	July 2026

1. Executive Summary	2
2. Scope and Authorization	3
3. Methodology	3
4. Tools Used	4
5. Detailed Findings	4
Finding 1 — Outdated SSH Service	4
Finding 2 — Outdated Web Server Software	5
Finding 3 — Missing Content Security Policy (CSP) Header	5
Finding 4 — Missing Anti-Clickjacking Protection	6
Finding 5 — Missing Strict-Transport-Security (HSTS) Header	6
Finding 6 — Server Software Version Disclosure	7
Finding 7 — Missing X-Content-Type-Options Header	7
Finding 8 — Minor Information Disclosures	8
6. Risk Summary Table	9
7. Conclusion	9
8. Screenshot Placement Guide	10

1. Executive Summary

This report presents the findings of a vulnerability assessment conducted against scanme.nmap.org, a publicly available test host maintained by the Nmap Security Scanner Project for the purpose of testing scanning tools. The assessment was carried out using passive and low-impact techniques only, and combined network service scanning, passive web application analysis, and manual browser-based verification.

The assessment identified eight distinct findings, primarily related to outdated service versions and missing HTTP security headers. No critical vulnerabilities were identified, and no exploitation, authentication bypass, or active attack techniques were used at any point. All findings are consistent with a lightly maintained public test server rather than a production business system, and each finding is paired with a proportionate, low-effort remediation recommendation.

Overall Risk Level: LOW to MEDIUM

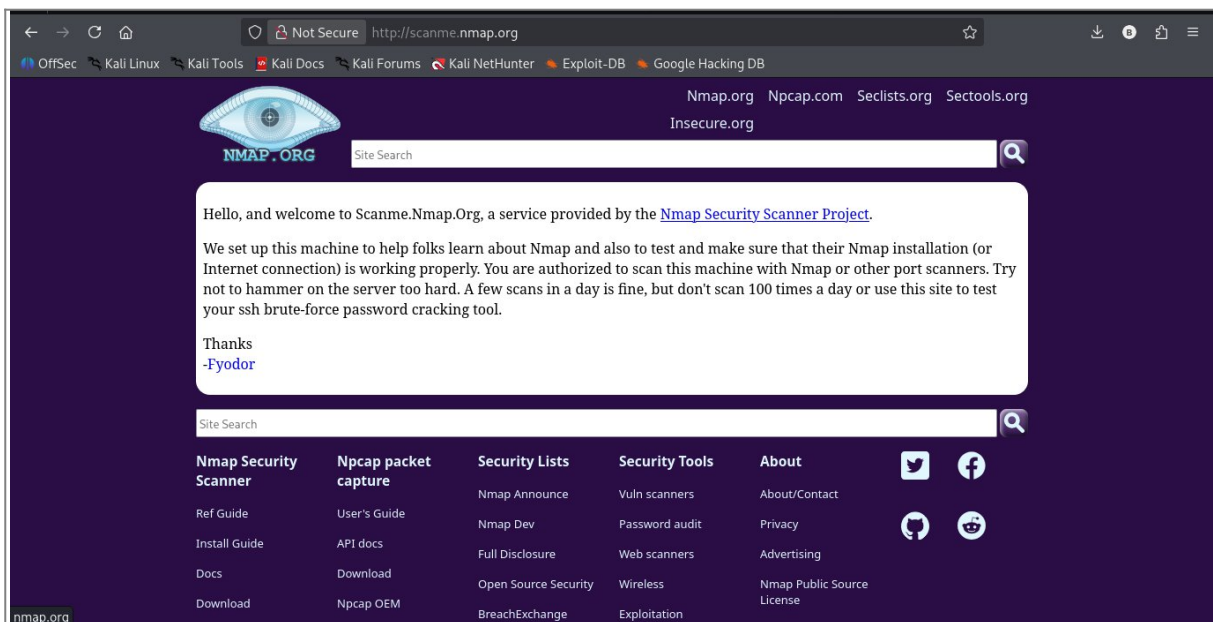


Figure 1: scanme.nmap.org homepage confirming the site's published scanning authorization.

2. Scope and Authorization

This assessment was limited strictly to the single host scanme.nmap.org. Only passive scanning and non-intrusive service enumeration techniques were used; no active exploitation, credential attacks, or denial-of-service techniques were performed at any stage. The target explicitly publishes permission for scanning and port-testing activity on its homepage, which was verified and documented as part of this engagement, satisfying the ethical and legal requirements for this assessment.

3. Methodology

Testing was conducted in three sequential, non-destructive phases:

1. Network Service Enumeration: Nmap was used to identify open ports, active services, and software version information on the target host.
2. Passive Web Application Analysis: OWASP ZAP was configured in passive mode to observe HTTP traffic generated by normal browsing and flag configuration weaknesses without transmitting any attack payloads.
3. Manual Verification: Browser Developer Tools were used independently of ZAP to inspect raw HTTP response headers, cross validating the automated findings.

No brute force, injection, or denial of service techniques were used at any point in this assessment, in accordance with the passive only scope defined for this task.

```
(zerotrace@Kali)-[~]
$ nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.8 openssl-3.6.3 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.6 nmap-libdnet-1.18.0 ipv6
Compiled without:
Available nsock engines: epoll poll select
```

Figure 2: Nmap version confirmation used for this assessment.

```
(zerotrace@Kali)-[~]
$ ping -c 4 scanme.nmap.org
PING scanme.nmap.org (45.33.32.156) 56(84) bytes of data:
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=1 ttl=39 time=678 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=2 ttl=39 time=545 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=3 ttl=39 time=488 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=4 ttl=39 time=490 ms

--- scanme.nmap.org ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3055ms
rtt min/avg/max/mdev = 488.337/550.528/677.944/77.056 ms
```

Figure 3: Connectivity test confirming target reachability and IP resolution (45.33.32.156).

4. Tools Used

Tool	Version	Purpose
Nmap	7.99	Port scanning and service/version detection
OWASP ZAP	2.17.0	Passive HTTP traffic analysis
Firefox DevTools	Built-in	Manual response header verification

5. Detailed Findings

Finding 1 — Outdated SSH Service

Risk Level: Medium

The target is running OpenSSH 6.1p1, a version released around 2014. Older software versions are more likely to contain security weaknesses that have since become publicly documented, which could give a potential attacker a research head start.

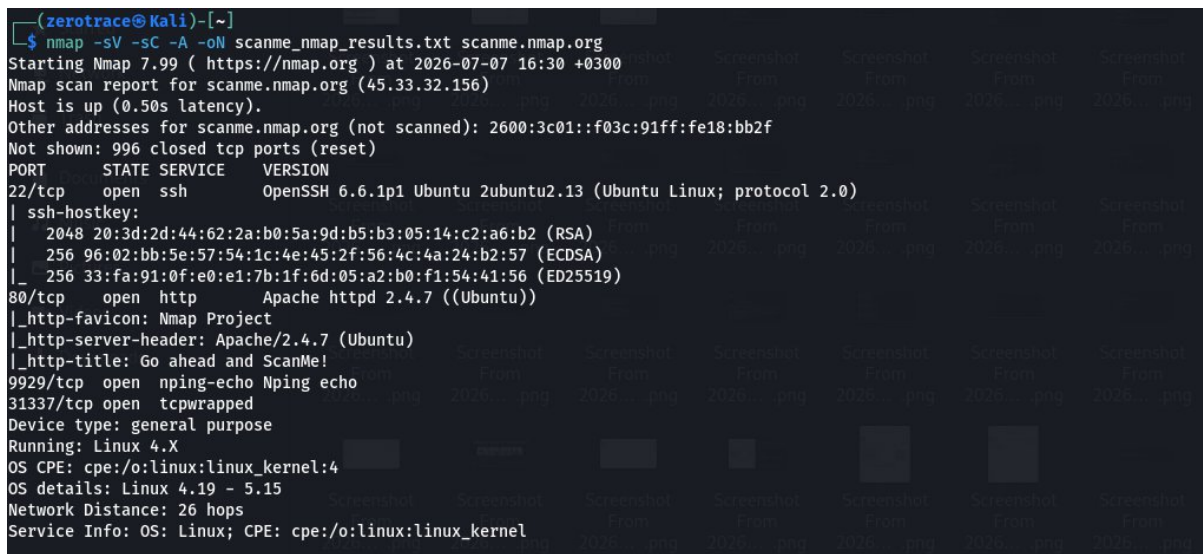
Recommendation: Upgrade OpenSSH to the latest stable release and maintain a regular patching schedule.

Finding 2 — Outdated Web Server Software

Risk Level: Medium

The web server identifies itself as Apache 2.4.7, also released around 2014. As with Finding 1, running older server software increases exposure to known, publicly documented vulnerabilities.

Recommendation: Upgrade Apache httpd to the current stable release and enable automatic security patching where feasible.



```
(zerotrace@Kali)-[~]
$ nmap -sV -sC -A -oN scanme_nmap_results.txt scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-07 16:30 +0300
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.50s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ _http-favicon: Nmap Project
|_ _http-server-header: Apache/2.4.7 (Ubuntu)
|_ _http-title: Go ahead and ScanMe!
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 26 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 4: Nmap scan output showing open ports and service versions.

```

TRACEROUTE (using port 21/tcp)
HOP RTT ADDRESS
1 1.39 ms 192.168.1.1
2 38.46 ms 10.144.1.254
3 266.42 ms 10.88.35.139
4 266.55 ms 10.88.35.138
5 84.06 ms 10.88.35.164
6 358.21 ms 10.88.35.170
7 135.26 ms 10.88.35.151
8 ...
9 231.87 ms 102.134.23.28
10 292.97 ms 154.66.247.161
11 436.91 ms 154.66.247.143
12 251.15 ms 154.66.247.92
13 323.54 ms 154.66.247.99
14 ... 15
16 508.21 ms port-channel4.core2.orf2.he.net (184.104.188.213)
17 455.17 ms port-channel1.core3.ash1.he.net (184.105.222.173)
18 ...
19 455.17 ms be47.core2.ash1.he.net (184.105.81.219)
20 455.19 ms be9.core1.pao1.he.net (184.104.188.34)
21 468.06 ms be9.core2.fmt2.he.net (184.105.222.5)
22 525.39 ms as63949.sfmix.org (206.197.187.40)
23 ... 25
26 455.28 ms scanme.nmap.org (45.33.32.156)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.19 seconds

```

Figure 5: Nmap traceroute and operating system detection output.

Finding 3 — Missing Content Security Policy (CSP) Header

Risk Level: Medium

The site does not define a Content Security Policy. This header instructs the browser on which sources of content, such as scripts and images, it should trust, reducing exposure to certain types of content injection.

Recommendation: Implement a CSP header that explicitly whitelists trusted content sources.

Finding 4 — Missing Anti-Clickjacking Protection

Risk Level: Medium

No X-Frame-Options header is present. Without this control, the page could potentially be embedded within a hidden frame on another site, which could be used to mislead users into unintended interactions.

Recommendation: Add an X-Frame-Options: SAMEORIGIN header, or an equivalent Content-Security-Policy frame-ancestors directive.

Finding 5 — Missing Strict-Transport-Security (HSTS) Header

Risk Level: Medium

No HSTS header is present to enforce secure connections. Without it, browsers are not instructed to always prefer an encrypted connection to this host.

Recommendation: Implement an HSTS header to enforce secure transport on all future connections.

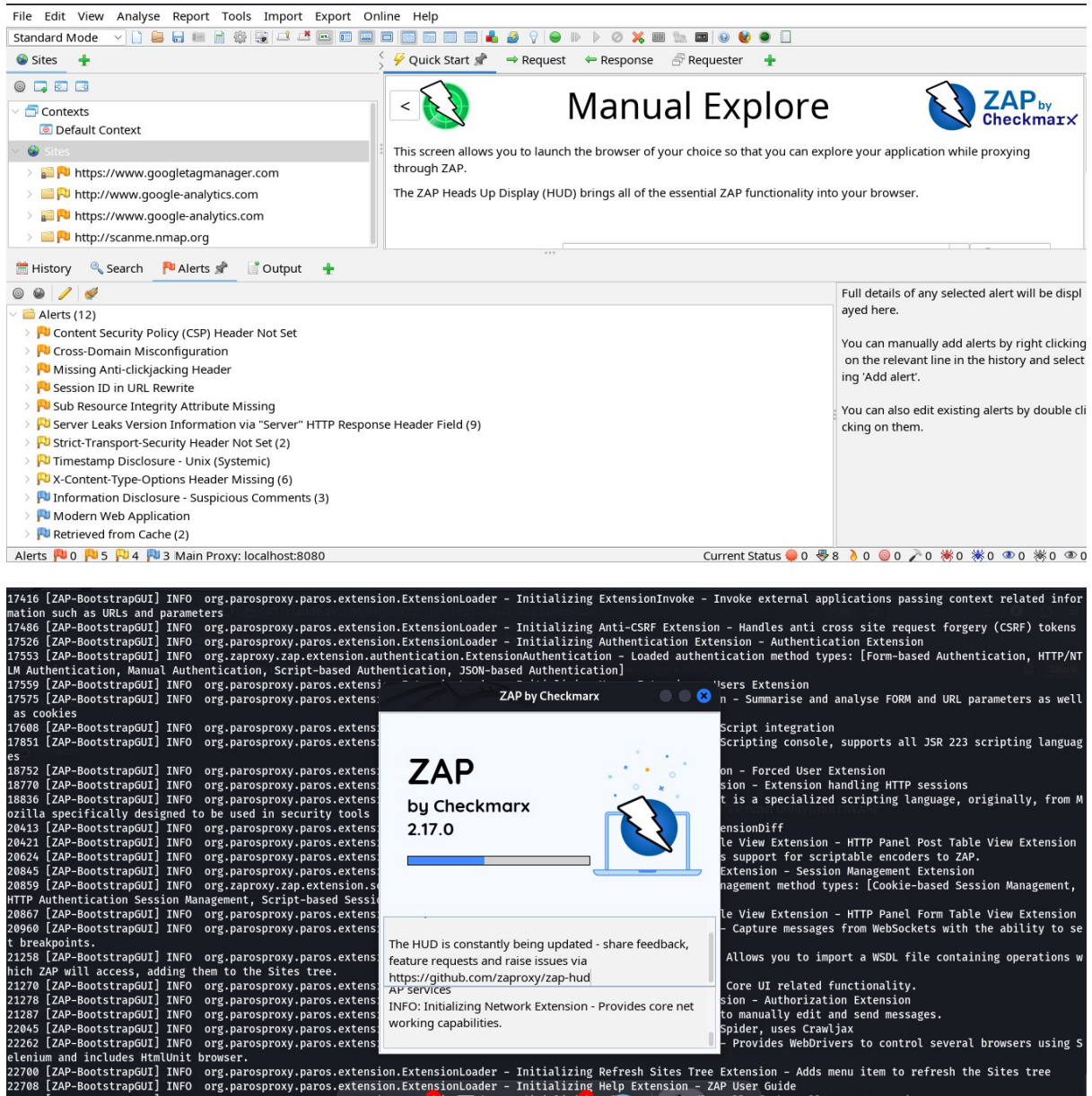
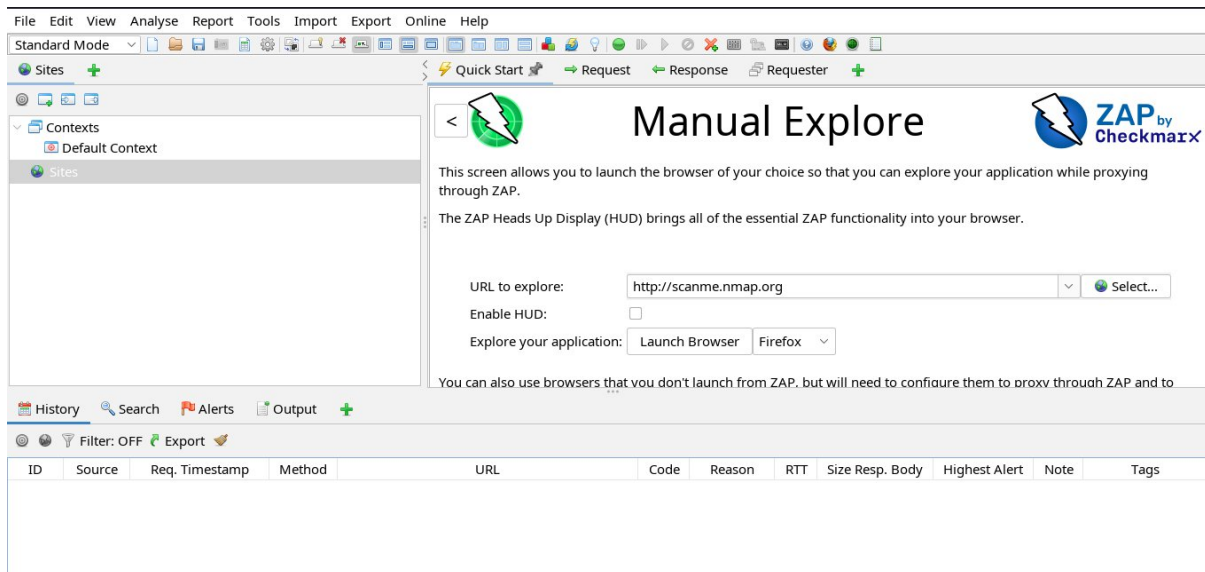


Figure 6: OWASP ZAP passive scan results showing all identified alerts.



Finding 6 — Server Software Version Disclosure

Risk Level: Low

The server's response headers disclose the exact software name and version (Apache/2.4.7), giving a potential attacker a starting point for researching known weaknesses associated with that specific release.

Recommendation: Configure the server to suppress or generalize the Server response header.

Finding 7 — Missing X-Content-Type-Options Header

Risk Level: Low

No X-Content-Type-Options: nosniff header is present. Its absence means browsers may, in certain conditions, attempt to guess file content types, which can occasionally be leveraged in content based attacks.

Recommendation: Add the X-Content-Type-Options: nosniff header to all HTTP responses.

Finding 8 — Minor Information Disclosures

Risk Level: Low / Informational

A small number of internal timestamps and developer comments were observed in page responses. These do not represent a direct exploitation path but constitute unnecessary information exposure.

Recommendation: Review and remove unnecessary comments and debug artifacts from production facing responses.

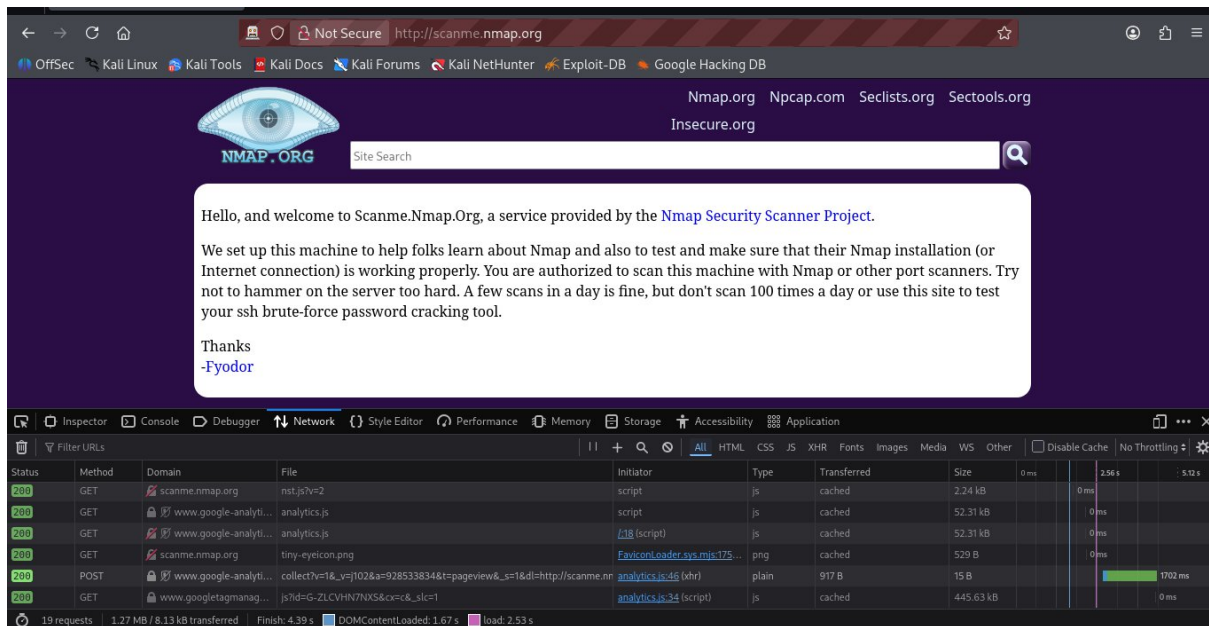
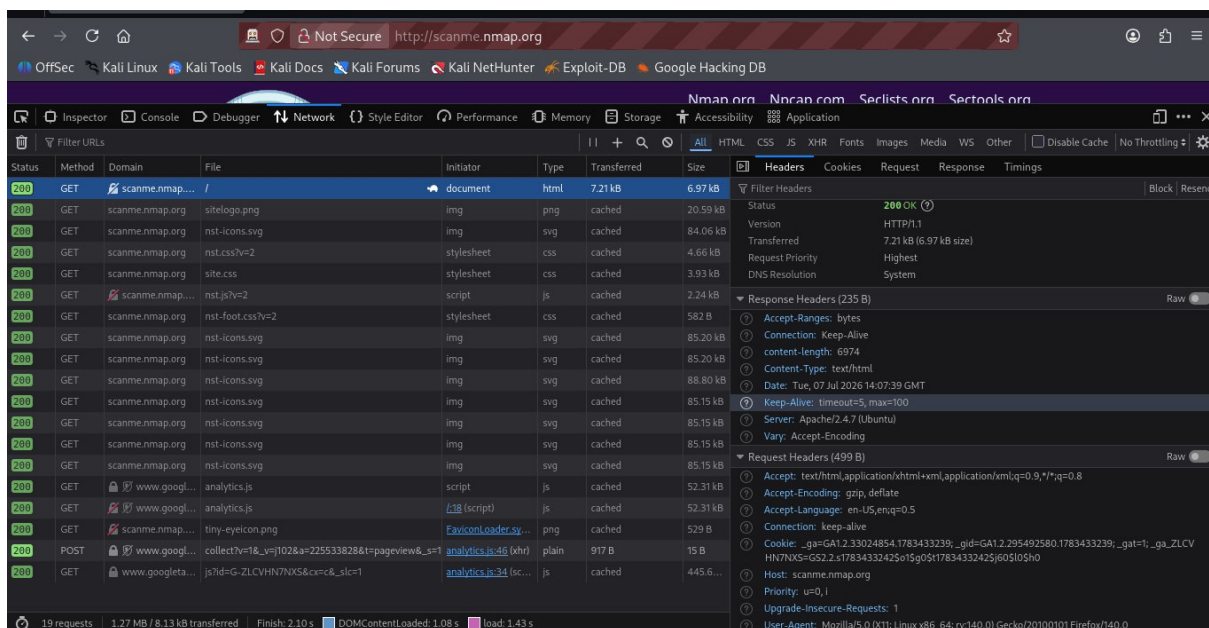


Figure 7: Browser DevTools response headers, cross verifying the ZAP findings.



6. Risk Summary Table

#	Finding	Risk Level
1	Outdated SSH Service	Medium
2	Outdated Web Server Software	Medium
3	Missing Content Security Policy Header	Medium
4	Missing Anti-Clickjacking Header	Medium
5	Missing Strict-Transport-Security Header	Medium

#	Finding	Risk Level
6	Server Version Disclosure	Low
7	Missing X-Content-Type-Options Header	Low
8	Minor Information Disclosures	Low / Informational

7. Conclusion

This assessment of scanme.nmap.org did not identify any critical vulnerabilities. The findings observed reflect a consistent pattern of outdated software versions and absent baseline HTTP security headers, all of which were identified using exclusively passive and non-intrusive techniques, in line with the defined scope of this engagement.

The recommendations outlined in this report are low effort to implement and represent standard baseline hardening practices appropriate for any public facing web server. Addressing the outdated software components and implementing the missing security headers would meaningfully reduce the host's overall attack surface without requiring architectural changes.

8. Screenshot Placement Guide

The table below summarizes where each screenshot belongs within this report. Each figure should be inserted at its marked placeholder location above, with the caption already provided directly underneath it.

Figure	Content	Report Section
Figure 1	scanme.nmap.org homepage showing the published scanning authorization statement	Executive Summary
Figure 2	Terminal output of nmap --version confirming the Nmap version used	Methodology
Figure 3	Terminal output of the ping connectivity test confirming target reachability	Methodology
Figure 4	Full Nmap scan output showing open ports, services, and version information	Finding 1 and Finding 2
Figure 5	Nmap traceroute and OS detection output	Finding 1 and Finding 2
Figure 6	OWASP ZAP Alerts tab showing the full list of passive findings	Finding 3, 4 and 5
Figure 7	Browser DevTools Network tab showing the response headers of the main document request	Finding 6, 7 and 8